

Cyber Risk Assessment — Platform (NIST SP 800-30 Rev 1)

SECTION 04-compliance-ksa TYPE assessment STATUS **draft** OWNER Founder

UPDATED 2026-08-18

Conducted using the **NIST SP 800-30 Rev 1** methodology. NIST is used here as assessment structure only; **PDPL and SDAIA remain the binding regimes**.

Step 1 — Prepare

Purpose. Produce a defensible, system-tier cyber risk analysis that (a) supplies the ISO/IEC 27001 Clause 6.1.2 risk-assessment input required by `isms-scope-and-statement-of-applicability.md`, and (b) deepens the two cyber rows in `09-investor-relations/risk-register.xlsx`, which is enterprise-tier and carries only RR-013 (Firebase misconfiguration) and RR-021 (dependency supply chain) as cyber entries out of 25.

Scope. Tier 3 — the production systems behind `flygaca.com` and `captadel.com`: the Vite/React PWA, the Firebase Cloud Functions gateway, Firestore, the Captain Adel service, and the supporting Google Cloud tenancy.

Scale. Likelihood × Impact, 1–5 each, **deliberately identical to the scale in** `risk-register.xlsx` so rows map one-to-one and can be merged without rescoreing.

Assumptions and limitations — stated, not silent.

- No penetration test has been commissioned. No production ASV scan exists.
- This assessment draws on a **defensive tooling sweep run 2026-08-18** across all five repositories (secret scanning over full git history, dependency advisories, Python SAST, workflow review, and a live security-header audit). That sweep had real gaps of its own: JavaScript/TypeScript SAST could not run, NVD/OSV correlation was unavailable, and no production endpoint was reachable. **Absence of a finding in those areas is not evidence of absence.**
- The EU VPS (Hostinger, Paris) is excluded: it serves the **public regulatory corpus only** and never personal data (`06-operations-it/hosting-facts.md`).

Step 2a — Threat sources

ID	Source	Type	Characterisation
TS-1	Opportunistic criminal	Adversarial	Automated credential stuffing, scraping, card testing. Low sophistication, high volume
TS-2	Targeted attacker	Adversarial	Motivated by the payment path or the B2B academy data. Moderate sophistication
TS-3	Supply-chain actor	Adversarial	Compromise of an npm/PyPI package or a GitHub Action rather than of us directly
TS-4	Malicious end user	Adversarial	A legitimate account abusing the LLM or quota surfaces
TS-5	Operator error	Accidental	Solo operator; misconfiguration is the dominant accidental source
TS-6	Provider outage	Structural	Google Cloud regional failure
TS-7	Regulatory/jurisdictional	Environmental	Data-residency exposure from out-of-Kingdom compute

Step 2b–2c — Threat events, vulnerabilities, predisposing conditions

Predisposing conditions — properties of the organisation that raise likelihood or impact independently of any single control:

- **PC-1 — Solo operator.** No separation of duties; one person holds production access, reviews their own changes, and is the single point of recovery.
- **PC-2 — Single-cloud concentration.** Google Cloud is simultaneously compute, authentication, database, and LLM inference. A single vendor account compromise is close to a total compromise, and there is no second provider for any layer.
- **PC-3 — Out-of-Kingdom compute.** Cloud Functions remain in `me-central1` (Doha) while Firestore is in `me-central2` (Dammam). Documented, owner-accepted, with a migration path — but live.
- **PC-4 — Unauthenticated LLM endpoint.** App Check on `/api/chat` is flag-gated and **off by default** (`runbooks/runbook-security-rollout.md` §1). CORS is not authentication.

Step 2d–2f — Risk determination

Ordered by score. "Evidence" distinguishes what was **observed** in the 2026-08-18 sweep from what is **inferred**.

ID	Threat event	ATT&CK	L	I	Score	Evidence	Existing control
CR-01	Firestore rules misconfiguration exposes cross-user data as the Instructor Dashboard adds cross-user reads	T1530	3	5	15	Inferred; design reviewed in <code>pdpl-pia-instructor-dashboard.md</code>	Scoped-summary architecture; <code>tests/rules/suite</code>
CR-02	Compromised GitHub Action executes in CI and exfiltrates deployment or signing secrets	T1195.001	3	5	15	Observed — 46 of 46 action references across all five repos are floating tags; zero SHA-pinned. <code>FirestoreExtended/action-hosting-deploy@v0</code> sits in the workflow holding Firebase deploy credentials	None currently
CR-03	Credential still live in git history is harvested and abused	T1552.001	4	3	12	Observed — five provider credentials remain in history: four in Money-Printer, one Gemini key in Captain-Adel. Working trees are clean; history is not; none rotated	Tips scrubbed; rotation outstanding
CR-04	Prompt injection subverts Captain Adel, especially in Arabic	ATLAS AML.T0051	4	3	12	Observed — the injection guard's 11 patterns are English-only; Arabic equivalents of the same phrases are not flagged, so no hardening note is applied on the Arabic path	Soft-flag guard (<code>guards.js</code>); grounding/cite-or-refuse layer
CR-05	Payment-page script tampering captures cardholder data (Magecart)	T1059.007	2	5	10	Observed — Moyasar widget injected with no SRI; four CSP sources disagree on whether <code>cdn.moyasar.com</code> is permitted	CSP on the canonical origin; see <code>pci-dss-scope-and-saq-determination.md</code>
CR-06	Vulnerable transitive dependency reached in production	T1195.001	3	3	9	Observed — 7 moderate advisories in both Node repos, common root <code>firebase-admin</code> → <code>retry-request</code> → <code>teeny-request</code> . Understated: NVD/OSV were unreachable	Dependabot on three repos
CR-07	LLM quota abuse / cost exhaustion via the unauthenticated chat endpoint	T1496	3	3	9	Inferred from PC-4	Rate limiting; free-tier quota meter (fails open by design)

ID	Threat event	ATT&CK	L	I	Score	Evidence	Existing control
CR-08	Regional outage in me-central2 interrupts service	—	2	4	8	Inferred	BCP/DR plan
CR-09	Regulatory exposure from out-of-Kingdom compute processing personal data	—	2	4	8	Observed — PC-3, plus two internal documents disagreeing on the fact	Documented migration path
CR-10	Account takeover via credential stuffing on Firebase Auth	T1110.004	3	2	6	Inferred	Firebase Auth defaults
CR-11	Undetected application vulnerability in the web/gateway code	—	3	3	9	Coverage gap, not a clean result — JS/TS SAST could not run; the two largest codebases are unscanned	Code review only

Step 3 — Communicate

Feeds into 09-investor-relations/risk-register.xlsx :

This assessment	Existing row
CR-01	Deepens RR-013 (Firebase misconfiguration)
CR-02, CR-06	Deepen RR-021 (dependency supply chain)
CR-08	Relates to RR-014
CR-03, CR-04, CR-05, CR-09, CR-11	No existing row — propose new entries

The register currently has no row for credential exposure, prompt injection, payment-page integrity, data residency, or SAST coverage. That is the substantive gap this assessment closes.

Steps 4–5 — Treatment and monitoring

Immediate (days):

1. **Rotate the five credentials** (CR-03). The only item where delay compounds exposure.
2. **Pin GitHub Actions to SHAs and add least-privilege permissions: blocks** (CR-02). Mechanical.

Short term (weeks): 3. Arabic injection patterns plus bilingual eval coverage (CR-04). 4. Firestore rules tests for cross-school and revoked-consent denial, in CI, before the dashboard ships (CR-01). 5. SRI or CSP-nonce for the Moyasar script; reconcile the four CSP sources (CR-05). 6. Run SAST in CI, where egress is available (CR-11).

Tracked: 7. Complete the `me-central1` → `me-central2` migration (CR-09), and resolve the `hosting-facts.md` contradiction. 8. Enable App Check on `/api/chat` (CR-07, PC-4) using the existing rollout procedure.

Review cadence. Annually, or on any of: a new cross-user data path, a change to the payment integration, a new sub-processor, or a completed region migration. Treatment actions route to the `Mitigation Tracker` sheet of the risk register.

Related: `pci-dss-scope-and-saq-determination.md`, `pdpl-pia-instructor-dashboard.md`, `isms-scope-and-statement-of-applicability.md`, `information-security-policy.docx`, `business-continuity-and-disaster-recovery-plan-bcp-dr.docx`, `09-investor-relations/risk-register.xlsx`.

DRAFT